



Data Protection Impact Assessment (DPIA)

Telemedicine Healthcare Platform – MediCareNow

Prepared By:

Ritik Kumar Gupta

B.A. LL.B. | Privacy, Data protection & Compliance Professional

Frameworks References:

- GDPR
- DPDP Act, 2023
- EDPB DPIA Guidelines
- ISO/IEC 270001 Risk principles

Date:

May 2026

Version:

1.0

Confidentiality:

For educational and portfolio purposes only

Table of Contents

0	OVERVIEW OF THE PROCESSING	3
0.1	Controller(s)	3
0.2	Processor(s) and sub-processor(s)	3
0.3	Name of the processing	3
0.4	Planning of the processing	4
0.5	DPPIA technical sheet.....	5
1	SYSTEMATIC DESCRIPTION OF THE PROCESSING	7
1.1	High-level description of the processing	7
1.1.a	Processed personal data	7
1.1.b	Purposes of the processing	7
1.1.c	Secondary or compatible uses.....	8
1.1.d	Nature, scope and context of the processing	9
1.2	Functional description	10
1.3	Means of processing, supporting assets and underlying architecture	10
1.4	Compliance with approved codes of conduct	10
2	ANALYSIS OF THE PROCESSING	11
2.1	Lawfulness of the processing	11
2.1.a	Legal basis	11
2.1.b	Reasons to lift the processing prohibition	12
2.2	Data minimisation, retention periods, and data quality	14
2.2.a	Data minimisation and retention periods.....	14
2.2.b	Data quality	15
2.3	Measures supporting compliance.....	15
2.3.a	Measures supporting compliance with principles in Article 5(1)(a-f) GDPR....	15
2.3.b	Measures supporting the exercise of data subjects' rights	17
2.3.c	Measures supporting compliance with other GDPR requirements	17
2.3.d	Measures supporting data protection by design and by default	18
2.3.e	Measures supporting security of processing	19
3	CONSIDERATIONS ON NECESSITY AND PROPORTIONALITY	20
3.1	Impacts of the processing on the rights and freedoms of data subjects.....	20
3.2	Assess the necessity of the processing.....	21
3.3	Assess the proportionality of the processing	21
4	RISK ASSESSMENT AND MANAGEMENT	23
4.1	Risk assessment and management	23

4.1.a Impacts on the rights and freedoms of the data subjects caused by non-default, accidental, unlawful, or abnormal events	23
4.1.b Method	23
4.1.c Inherent risk assessment	25
4.2 Action plan	25
4.2.a Additional mitigating measures	25
4.2.b Residual risk assessment	26
4.2.c Plan	27
5 INVOLVEMENT OF INTERESTED PARTIES	27
5.1 DPO advice	27
5.2 Views of data subjects or their representatives	28
6 CONCLUSION AND DECISION	28

The European Data Protection Board has adopted the following template:

0 OVERVIEW OF THE PROCESSING

0.1 Controller(s)

Note: If there are Joint controllers, one table per controller, adding a row to identify their obligations and tasks

Controller	MedicareNow Pvt Ltd
Management units responsible for the processing inside the organisation	IT Department and Healthcare Operation Team
Main establishment/point of contact or representative	MediCareNow Pvt Ltd, New Delhi, India (privacy@medicarenow.com)
Information about the DPO or similar function, if applicable	Not Available

0.2 Processor(s) and sub-processor(s)

	Processor	Definition of their obligations and tasks
1	Cloud service provider (AWS)	Tasks: Stores patient data and medical records on cloud server. Obligation: • Ensure data security through encryption and access controls. • Process data only on instructions of the controller • Prevent unauthorized access and data breaches • Maintain confidentiality of personal data
2	Email service provider	Tasks: Sends reports and notification to patients via email Obligation: • Ensure Secure transmission of data • Process data only for communication purposes
3	Payment Gateway	Tasks: Processes payments made by users Obligation: • Protect financial data of users using encryption • Comply with financial security standards • Ensure Confidentiality of data

0.3 Name of the processing

Internal name given to the processing (the given name in	Patient Data Management System
--	--------------------------------

the record of processing activities)	
Current version (explaining the history of changes made to the processing in the past, if any)	Not Applicable

0.4 Planning of the processing

Estimated launch date	February 2026
Estimated end date or expiration conditions (if applicable, i.e. because the processing is temporary)	Ongoing- no fixed end date

0.5 DPIA technical sheet

Current version and version log (explaining the history of changes made to the information contained in the DPIA template for this processing, if any)	Version 1.0 – Initial DPIA create for Telemedicine Patient Data Processing System
Team involved in conducting this DPIA (providing details of their roles, tasks, responsibilities, etc.)	Prepared by Ritik Kumar Gupta (Privacy Analyst – DPIA, Risk assessment, compliance analysis)
Guidelines, standards, codes of conduct and other reference materials used to conduct this DPIA ¹	GDPR (General Data Protection Regulation) DPDP Act,
Reasons to conduct the DPIA ²	1. New processing activity, DPIA likely to be required due to high-risk (legal obligation under Article 35.3 GDPR): ☐ Systematic and extensive evaluation of personal aspects relating to natural persons which is based on automated processing, including profiling, and on which decisions are based that produce legal effects concerning the natural person or similarly significantly affect the natural person. ☒ Processing on a large scale of special categories of data referred to in Article 9(1), or of personal data relating to criminal convictions and offences referred to in Article 10. ☐ Systematic monitoring of a publicly accessible area on a large scale. 2. New processing activity, DPIA likely to be required due to likely high-risk (legal obligation under national law): Explanation: _____ 3. New processing activity, DPIA likely to be required due to likely high-risk (following EDPB and national guidance): ☒ Evaluation or scoring, including profiling and predicting, especially from “aspects concerning the data subject’s performance at work, economic situation, health, personal preferences or interests, reliability or behaviour, location or movements”. ☐ Automated-decision making with legal or similar significant effect: processing that aims at taking decisions on data subjects producing “legal effects concerning the natural person” or which “similarly significantly affects the natural person”. ☐ Systematic monitoring: processing used to observe, monitor or control data subjects, including data collected through networks or “a systematic monitoring of a publicly accessible area”. ☒ Sensitive data or data of a highly personal nature: this includes special categories of personal data as defined in Article 9 (for example information about individuals’ political opinions), as well as personal data relating to criminal convictions or offences as defined in Article 10.

¹ Guidelines on Data Protection Impact Assessment (DPIA) (wp248rev.01), https://ec.europa.eu/newsroom/just/document.cfm?doc_id=47711

² Idem.

	☒ Data processed on a large scale, considering the number of data subjects concerned, either as a specific number or as a proportion of the relevant population; the volume of data and/or the range of different data items being processed; the duration, or permanence, of the data processing activity; the geographical extent of the processing activity. ☐ Matching or combining datasets. ☒ Data concerning vulnerable data subjects (because of the increased power imbalance between the data subjects and the data controller, meaning the individuals may be unable to easily consent to, or oppose, the processing of their data, or exercise their rights.) ☐ Innovative use or applying new technological or organisational solutions. ☐ When the processing in itself "prevents data subjects from exercising a right or using a service or a contract". ☐ Other (for example, national list regarding the processing operations subject to the requirement of a data protection impact assessment): _____ 4. New processing activity, DPIA necessary or beneficial: ☐ DPO opinion or recommendation. ☐ Data subjects' (or their representatives') opinion or recommendation. ☒ Required by a code of conduct, standard, best practice, etc. ☒ Other (for example for managing risk or demonstrating accountability and building trust): To build trust and manage privacy risk 5. Existing high-risk processing activity for which there has been a change of the risks: ☐ Data processing has changed. ☐ The organisational or societal context for the processing activity has changed. How? _____
Scope of this DPIA (what has been considered and what has been left out of the assessment and why)	This DPIA covers the collection, storage, processing, and sharing of patient personal and sensitive data within the telemedicine platform. It also includes assessment of data processing activities such as registration, consultation, report generation, and data storage. The assessment focuses on legal basis, risk identification, security measures, and compliance with data protection principles. This DPIA does not cover third-party systems such as payment gateway internal operations as they operated independently and also does not include physical data processing and offline records are not included as the processing is primary digital
Completion date	26 April 2026
Formal validation date (approval of the DPIA as complete and finished by a responsible official)	22 April 2026
Is the DPIA (or parts of it) intended to be published or to be shared externally?	☒ No ☐ Yes it is going to be published: How? _____ ☐ Yes, it is going to be shared externally: How? _____

1 SYSTEMATIC DESCRIPTION OF THE PROCESSING

1.1 High-level description of the processing

1.1.a Processed personal data

	Processed personal data (item or element)	Explanation (data type, data subject category, additional details)	Special category of personal data
1	Name	Personal data of patients used for identification and registration purposes	✓ No
2	Phone Number	Personal data of patients used for registration purpose	✓ No
3	Email	Personal data of patients used for registration and sending medical reports	✓ No
4	Medical Reports	Sensitive personal data of patients used for diagnosis	Yes: ☐ Data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership. ☐ Genetic data. ☐ Biometric data for the purpose of uniquely identifying a natural person. ☒ Data concerning health. ☐ Data concerning a natural person's sex life or sexual orientation.
5	Medical History	Sensitive personal data of patients used for treatment	

1.1.b Purposes of the processing

	Purpose: specific and explicit reasons for processing the personal data	Purpose: specific and explicit reasons for processing the personal data
1	Registration: To register patients on the platform and create user accounts	

2	Appointment & Consultation: To enable online consultation between patients and doctors	
3	Diagnosis: To analyze medical reports and provide accurate diagnosis	
4	Prescription: To generate and store electronic prescription for patients	
5	Communication: To communicate with patients regarding appointments, reports, and updates	
6	Data Storage: To securely store patient data for future medical reference and continuity of care	
7	Payment Processing: To process payments for services provided through platform	

1.1.c Secondary or compatible uses

	Secondary or compatible uses of the data	Personal data involved (considering personal data listed in 1.1.a), under what conditions and assessment of compatibility
1	Personal data may be used for internal analytics and service improvement purposes	Anonymized or aggregated patient data is used and the secondary use is compatible with original purpose of providing healthcare services, as it enhances service quality without impacting rights and freedom of data subjects
2		
N		

1.1.d Nature, scope and context of the processing

Nature of the processing: the way personal data will be handled (operations involved, technologies used, etc.).	The processing involves collection, storage, use, and sharing of personal and sensitive health data through a digital telemedicine platform. Data is collected via web and mobile applications, stored on cloud servers, access by authorized medical professionals. Processing includes registration, consultation, report generation, and communication with patients.
Scope of the processing: breadth and extent (the volume or scale given the number of data subjects or data items, geographical and organisational reach, frequency or duration for the data subject, etc.).	The processing is carried out on a large scale involving a vast number of patients across India. It includes multiple categories of personal and sensitive data such as medical records and health information. Data is processed continuously as part of ongoing telemedicine services and retained for defined period in accordance with retention policies.
Context of the processing: circumstances and environment (use cases, supported business processes, status of the controller and relationship with the data subjects, data subjects categories and potential vulnerable groups, cross-border processing, international transfers, etc.).	The processing takes places in a healthcare context where there is a high level of trust between parties and the service provider. The data subjects are patients, including potentially vulnerable individuals due to their health conditions. The processing is necessary to provide medical services and involves sensitive personal data. No cross-border data transfer is allowed. Is this a cross-border processing? ☒ No ☐ Yes (justification and details): _____ Is personal data going to be transferred to a recipient in a third country or international organisation? ☐ No ☐ Yes (justification and details): _____

1.2 Functional description

Note: Ideally, this table should be supplemented with one or more diagrams representing data flows or a similar figure.

	Processing phase or stage	Type of operations	Explanation
1	Data Collection	☒ Collection ☐ Use ☐ Storage ☐ Sharing and Transfer ☐ Deletion and Destruction	Patient enter personal and medical data during registration and uploads reports through the application
2	Data Storage	☒ Storage	Data is stored securely in cloud servers (AWS) for future use
3	Data Use	☒ Use	Doctors access patient data to provide consultation and diagnosis
4	Data Sharing	☒ Sharing and Transfer	Reports and prescription are shared with patients via email or mobile app
5	Data Retention	☒ Deletion and Destruction	Data is retained for a defined period and deleted after the retention period over

1.3 Means of processing, supporting assets and underlying architecture

Processing phase or stage (considering the functional description under 1.2)	Means of processing and supporting assets	Explanation
Data Collection	Web & Mobile Application	Patients enter personal and medical data through the application interface
Data Storage	Cloud Infrastructure (AWS), Database	Data is stored securely in cloud servers and managed using database systems
Data Use	Application System, User Interface	Doctors access data through secure login to provide consultation
Data Sharing	Email System, Mobile App	Reports and prescriptions are transmitted via email and app notifications
Data Retention	Cloud Storage	Data is retained in cloud servers for defined retention period

1.4 Compliance with approved codes of conduct

	Code of conduct	Explanation
--	-----------------	-------------

1	No formal approved code of conduct under applicable data protection regulations is followed	☐ Compliance is likely to be required (legal obligation). Why?: _____ ☐ Compliance is necessary or beneficial. Why?: _____
---	---	---

2 ANALYSIS OF THE PROCESSING

2.1 Lawfulness of the processing

2.1.a Legal basis

Purpose/use (considering 1.1.b on processing purposes and 1.1.c on secondary or compatible purposes)	Legal basis (Article 6(1) GDPR)	Justification (if applicable, analyse the legitimate interests pursued by the controller or by a third party conducting a balancing test ³)
Registration	☒ (a) The data subject has given consent to the processing of his or her personal data for one or more specific purposes. ☐ (b) The processing is necessary for the performance of a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract. ☐ (c) The processing is necessary for compliance with a legal obligation to which the controller is subject. ☐ (d) The processing is necessary in order to protect the vital interests of the data subject or of another natural person. ☐ (e) The processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller. ☐ (f) The processing is necessary for the purposes of the legitimate interests pursued by the controller or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data, in particular where the data subject is a child.	Patient provide their data voluntarily while signing up on the platform

³ EDPB Guidelines 1/2024 on processing of personal data based on Article 6(1)(f) GDPR:
https://www.edpb.europa.eu/system/files/2024-10/edpb_guidelines_202401_legitimateinterest_en.pdf

Online Consultation	✓ (b) The processing is necessary for the performance of a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract.	Processing is necessary to provide healthcare services requested by the patient
Diagnosis	✓ (a) The data subject has given consent to the processing of his or her personal data for one or more specific purposes.	Sensitive health data is processed with patient consent for providing medical services
Communication	✓ (a) The data subject has given consent to the processing of his or her personal data for one or more specific purposes.	Patient agree to receive notifications and updates
Data Storage	✓ (f) The processing is necessary for the purposes of the legitimate interests pursued by the controller or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data, in particular where the data subject is a child.	Necessary for maintaining medical records and continuity of care
Payment processing	✓ (b) The processing is necessary for the performance of a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract.	Require to complete service transaction
Internal analytics and service improvement purposes (secondary use)	✓ (a) The data subject has given consent to the processing of his or her personal data for one or more specific purposes.	Data is anonymized and used for service improvement without identifying individuals

2.1.b Reasons to lift the processing prohibition

Special category of personal data (item or element, considering 1.1.a)	Reasons to lift the processing prohibition (Article 9(2) GDPR)	Justification
Medical History	✓ (a) The data subject has given explicit consent to the processing of those personal data for one or more specified purposes, except where Union or Member State law provide that the prohibition may not be lifted by the data subject. □ (b) The processing is necessary for the purposes of carrying out the obligations and exercising specific rights of the controller or of the data subject in the field of employment and social security and social protection law	The processing of sensitive health data is essential for diagnosis, treatment, and medical consultation. Data subjects provide explicit consent before processing, and appropriate safeguards are implemented to protect

	in so far as it is authorised by Union or Member State law or a collective agreement pursuant to Member State law providing for appropriate safeguards for the fundamental rights and the interests of the data subject. ☐ (c) The processing is necessary to protect the vital interests of the data subject or of another natural person where the data subject is physically or legally incapable of giving consent. ☐ (d) The processing is carried out in the course of its legitimate activities with appropriate safeguards by a foundation, association or any other not-for-profit body with a political, philosophical, religious or trade union aim and on condition that the processing relates solely to the members or to former members of the body or to persons who have regular contact with it in connection with its purposes and that the personal data are not disclosed outside that body without the consent of the data subjects. ☐ (e) The processing relates to personal data which are manifestly made public by the data subject. ☐ (f) The processing is necessary for the establishment, exercise or defence of legal claims or whenever courts are acting in their judicial capacity. ☐ (g) The processing is necessary for reasons of substantial public interest, on the basis of Union or Member State law which shall be proportionate to the aim pursued, respect the essence of the right to data protection and provide for suitable and specific measures to safeguard the fundamental rights and the interests of the data subject. ✓ (h) The processing is necessary for the purposes of preventive or occupational medicine, for the assessment of the working capacity of the employee, medical diagnosis, the provision of health or social care or treatment or the management of health or social care systems and services on the basis of Union or Member State law or pursuant to contract with a health professional and subject to the conditions and safeguards referred to in paragraph 3 article 9 GDPR. ☐ (i) The processing is necessary for reasons of public interest in the area of public health, such as protecting against serious cross-border threats to health or ensuring high standards of quality and safety of health care and of medicinal products or medical devices, on the basis of Union or Member State law which provides for suitable and specific measures to safeguard the rights and freedoms of the data subject, in particular professional secrecy. ☐ (j) The processing is necessary for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes in accordance with Article 89(1) GDPR based on Union or Member State law which shall be proportionate to the aim pursued, respect the essence of the right to data protection and provide for suitable and specific measures to safeguard the fundamental rights and the interests of the data subject.	their rights and confidentiality
Medical Reports	✓ (a) The data subject has given explicit consent to the processing of those personal data for one or more	The processing of sensitive health data is essential for

	specified purposes, except where Union or Member State law provide that the prohibition may not be lifted by the data subject. ✓ (h) The processing is necessary for the purposes of preventive or occupational medicine, for the assessment of the working capacity of the employee, medical diagnosis, the provision of health or social care or treatment or the management of health or social care systems and services on the basis of Union or Member State law or pursuant to contract with a health professional and subject to the conditions and safeguards referred to in paragraph 3 article 9 GDPR.	diagnosis, treatment, and medical consultation. Data subjects provide explicit consent before processing, and appropriate safeguards are implemented to protect their rights and confidentiality
--	---	---

2.2 Data minimisation, retention periods, and data quality

2.2.a Data minimisation and retention periods

Processed personal data (item or element, considering 1.1.a)	Justification of the need and relevance of the data	Recipients	Justification	Retention period	Justification
Name	Required for patient identification and account creation	Doctors, Admin staff	Needed to identify patient during consultation	5 years	Required for medical records and continuity of care
Phone Number	Required for Communication and appointment update	Admin, Communication system	Needed to notify patients	2 years	Retained for service-related communication
Email	Required for sending reports and notifications	Email system, Admin	Needed for report delivery	2 years	Used for communication purpose
Medical Reports	Required for diagnosis and treatment	Doctors	Essential for medical decision-making	5 years	Required for medical history and legal compliance
Medical History	Required for ongoing treatment	Doctors	Ensures continuity of care	5 years	Important for long term health care
Prescriptions	Required to provide treatment details	Patient, Doctors	Needed for treatment and reference	5 years	Required for future medical reference
Payment Data	Required for transaction processing	Payment gateway	Necessary for completing transactions	7 years	Financial/ legal compliance requirements

2.2.b Data quality

Processed personal data (item or element, considering table 1.1.a)	Quality metrics, requirements or thresholds	Justification
Name	Must be accurate and complete	Incorrect name may lead to misidentification of patient
Phone Number	Must be valid and active	Required for communication and appointment updates
Email	Must be valid format and functional	Ensure delivery of reports and notifications
Medical Reports	Must be accurate, complete, and verified	Incorrect date may lead to wrong diagnosis
Medical History	Must be accurate and regularly updated	Require for proper treatment decisions
Prescriptions	Must be accurate and clearly recorded	Ensures correct medication and patient safety

2.3 Measures supporting compliance

2.3.a Measures supporting compliance with principles in Article 5(1)(a-f) GDPR

Compliance with Article 5(1)(a-f) GDPR principles	List of supporting measures	Discussion of appropriateness and effectiveness	Implementation status
Fairness principle	Privacy Notice	Ensure users are informed and provide consent before processing	☐ Planned ☐ Partially implemented ☒ Implemented
Transparency principle	Privacy notice, consent mechanism	Ensures notice should be kept simple and understandable to users to maintain transparency	☐ Planned ☐ Partially implemented ☒ Implemented
Purpose limitation principle	Defined processing purposes, internal policies	Data is used only for healthcare services and not for unrelated purposes	☐ Planned ☐ Partially implemented ☒ Implemented

Data minimisation principle	Limited data collection fields	Only necessary data is collected for providing services	☐ Planned ☐ Partially implemented ☒ Implemented
Accuracy principle	Data validation, user update options	Ensures data remains accurate and up to date	☐ Planned ☐ Partially implemented ☒ Implemented
Storage limitation principle	Retention policy, data deletion mechanism	Data is retained only for defined period and deleted thereafter	☐ Planned ☐ Partially implemented ☒ Implemented
Integrity and confidentiality principle	Encryption, access control, authentication	Protect data from unauthorized access and breaches	☐ Planned ☐ Partially implemented ☒ Implemented
Accountability principle	DPIA documentation, RoPA, internal policies, and audit logs	Ensures that the organization can demonstrate compliance with data protection laws through proper documentation and monitoring	☐ Planned ☐ Partially implemented ☒ Implemented

2.3.b Measures supporting the exercise of data subjects' rights

Data subject rights	List of supporting measures	Discussion of appropriateness and effectiveness	Implementation status
Information to be provided to the data subjects (Articles 12, 13 and 14 GDPR)	Privacy notice, consent forms, app-based disclosure	Ensures transparency by informing users about data collection, purpose, and rights before processing	☐ Planned ☐ Partially implemented ☒ Implemented
Right of access and to data portability (Articles 15 and 20 GDPR)	User request via email/app, data export feature	Enable users to access their data and receive it in structured format	☐ Planned ☒ Partially implemented ☐ Implemented
Right to rectification and to erasure (Articles 16, 17 and 19 GDPR)	Profile update option, deletion request system	Allows correction and deletion of inaccurate or unnecessary data	☐ Planned ☐ Partially implemented ☒ Implemented
Right to object and to restriction of processing (Article 18, 19 and 21 GDPR)	User request handling system, admin controls	Enable users to object to processing or restrict use of their data	☐ Planned ☒ Partially implemented ☐ Implemented
Right not to be subject to a decision based solely on automated processing (Article 22 GDPR)	No automated decision-making system used	No decision are made solely by automated processing, ensuring human involvement	☐ Planned ☐ Partially implemented ☒ Implemented

2.3.c Measures supporting compliance with other GDPR requirements

Compliance with other GDPR requirements	List of supporting measures	Discussion of appropriateness and effectiveness	Implementation status
Requirements on the provisions and withdrawal of consent (Article 7 GDPR)	Consent checkbox, clear privacy notice, withdrawal option in app	Ensures consent is freely given, informed, and can be withdrawn easily at any time	☐ Planned ☐ Partially implemented ☒ Implemented
Relationship with processors (Article 28 GDPR)	Data processing agreements (DPA), vendor assessment	Ensures processor act only on instructions and maintain data security	☐ Planned ☐ Partially implemented ☒ Implemented

Safeguards relating to international transfer(s) (Chapter V GDPR)	No international data transfers OR use of secure cloud with safeguards	Data is processed within India; no cross-border transfer reduces risk	☐ Planned ☐ Partially implemented ☒ Implemented
---	--	---	---

2.3.d Measures supporting data protection by design and by default

Data protection by design and by default (Article 25 GDPR)	List of supporting measures	Discussion of appropriateness and effectiveness	Implementation status
Data Minimisation	Limited data field in registration	Ensures only necessary data is collected, reducing privacy risks	☐ Planned ☐ Partially implemented ☒ Implemented
Access Control	Role-based access for doctors/admin	Prevent unauthorized access to sensitive data	☐ Planned ☐ Partially implemented ☒ Implemented
Encryption	HTTPS encryption, secure cloud storage	Protects data during storage and transmission	☐ Planned ☐ Partially implemented ☒ Implemented
Default privacy setting	No automatic haring of data with third parties without user's consent	Ensures privacy is protected by default	☐ Planned ☐ Partially implemented ☒ Implemented
Consent Mechanism	Consent checkbox before processing	Ensure user control over data processing	☐ Planned ☐ Partially implemented ☒ Implemented
Monitoring and Logs	System logs and monitoring	Partially implemented	☐ Planned ☒ Partially implemented ☐ Implemented

2.3.e Measures supporting security of processing

Security of processing (Article 32 GDPR)	List of supporting measures	Discussion of appropriateness and effectiveness	Implementation status (planned/partially implemented/implemented)
Encryption	HTTPS encryption, cloud encryption (AWS)	Protects data during transmission and storage from unauthorized access	☐ Planned ☐ Partially implemented ☒ Implemented
Access Control	Role-based access, login authentication	Ensures only authorized users can access sensitive data	☐ Planned ☐ Partially implemented ☒ Implemented
Authentication mechanism	Username-password login system	Prevents unauthorized system access	☐ Planned ☐ Partially implemented ☒ Implemented
Data Backup	Cloud backup systems	Ensures data availability and recovery in case of system failure	☐ Planned ☐ Partially implemented ☒ Implemented
Logging and Monitoring	System logs, activity tracking	Helps data suspicious activity and unauthorized access	☐ Planned ☐ Partially implemented ☒ Implemented
Data Masking	Limited display of sensitive information	Reduced exposure of sensitive information	☒ Planned ☐ Partially implemented ☐ Implemented

3 CONSIDERATIONS ON NECESSITY AND PROPORTIONALITY

3.1 Impacts of the processing on the rights and freedoms of data subjects

	Threats posed by the processing, as it has been designed and planned to be implemented (including technical, legal/contractual and organisational measures to mitigate risk(s))	How can it be materialised?	Risk sources (purpose, wrong design and weaknesses, exposures, etc.)	Impact on data subjects' rights and freedoms
1	Data Breach of sensitive health data	Hacking or unauthorized system access	Weak security controls or system vulnerabilities	Exposure of sensitive health information leading to privacy violation and reputational harm
2	Unauthorized Access by internal staff	Lack of proper access control	Poor role-based access design	Misuse of patient data and breach of confidentiality
3	Wrong Data Sharing of medical reports	Human error or system error	Weak validation and process controls	Disclosure of sensitive data to wrong person
4	Loss of data	System failure or accidental deletion	Loss of backup or recovery system	Loss of medical history affecting treatment
5	Unauthorized login	Weak passwords or stolen credentials	Poor authentication system	Unauthorized access to patient data

3.2 Assess the necessity of the processing⁴

Evaluate if the envisaged processing is effective and the least intrusive for the data subject's rights and freedoms⁵. Provide evidence (for example, concerning the different considered alternatives) and justification.

The processing of personal and sensitive data is necessary to provide telemedicine services, including patient registration, diagnosis, consultation, and prescription generation. Without processing such data, the organization would be unable to deliver healthcare services effectively.

The processing is effective as it enables accurate diagnosis, communication, and continuity of care through digital systems. The use of structured data and cloud-based systems ensures efficient handling of patient information.

The processing is designed to be the least intrusive by limiting data collection to only what is necessary for healthcare purposes. Alternative approaches such as collecting excessive or unrelated data were not adopted. Where possible, data is minimized and anonymized for secondary uses such as analytics.

Therefore, the processing is proportionate, necessary, and aligned with the rights and freedoms of data subjects.

3.3 Assess the proportionality of the processing⁶

Discuss the importance of the processing and its potential benefits for the data subject and collectively. Conduct an evaluation that compares the potential impacts on rights and freedoms of data subjects with the advantages resulting from the processing, to ensure that the processing is proportional and fairly balanced. Provide evidence and justification.

The processing of personal and sensitive data is essential for providing telemedicine services, including diagnosis, consultation, and treatment. It plays a critical role in enabling access to healthcare services, especially for individuals who may not have easy access to physical medical facilities.

The processing provides significant benefits to data subjects, including timely medical consultation, improved healthcare outcomes, and convenience. At a broader level, it contributes to efficient healthcare delivery and improved public health services.

However, the processing involves handling sensitive health data, which may pose risks to the rights and freedoms of data subjects, such as privacy breaches or unauthorized access.

4 EDPS "Assessing the necessity of measures that limit the fundamental right to the protection of personal data: A Toolkit", https://www.edps.europa.eu/sites/default/files/publication/17-04-11_necessity_toolkit_en_0.pdf

5 EDPB "Guidelines 1/2024 on processing of personal data based on Article 6(1)(f) GDPR", section II.B, paragraph 29, https://www.edpb.europa.eu/system/files/2024-10/edpb_guidelines_202401_legitimateinterest_en.pdf ; See also EDPB "Opinion 11/2024 on the use of facial recognition to streamline airport passengers' flow (compatibility with Articles 5(1)(e) and(f), 25 and 32 GDPR, Version 1.1, adopted on 23 May 2024", paragraph 32, https://www.edpb.europa.eu/system/files/2024-05/edpb_opinion_202411_facialrecognitionairports_en.pdf

6 EDPS "Guidelines on assessing the proportionality of measures that limit the fundamental rights to privacy and to the protection", https://www.edps.europa.eu/sites/default/files/publication/19-02-25_proportionality_guidelines_en.pdf ; See also EDPB "Opinion 11/2024 on the use of facial recognition to streamline airport passengers' flow (compatibility with Articles 5(1)(e) and(f), 25 and 32 GDPR, Version 1.1, adopted on 23 May 2024", paragraph 32, https://www.edpb.europa.eu/system/files/2024-05/edpb_opinion_202411_facialrecognitionairports_en.pdf

These risks are mitigated through appropriate technical and organizational measures, including encryption, access control, and data minimization. As a result, the impact on data subjects is reduced to an acceptable level.

The benefits of the processing outweigh the potential risks, and appropriate safeguards are in place to ensure that the processing remains fair, balanced, and proportionate.

4 RISK ASSESSMENT AND MANAGEMENT

4.1 Risk assessment and management

4.1.a Impacts on the rights and freedoms of the data subjects caused by non-default, accidental, unlawful, or abnormal events

Note: Identify, at least, threats that could lead to illegitimate access, undesired modification and disappearance of data.

Threats posed by malfunctions and deviations from design and default, threats to data confidentiality, integrity and availability (related to cybersecurity), etc.		How can it be materialised?	Risk sources (exposures and errors, vulnerabilities etc.)	Impacts on data subjects' rights and freedoms
1	Unauthorized access to sensitive health data	Cyberattack or hacking of system	Potential system vulnerabilities	Exposure of sensitive medical data leading to privacy violation, reputational harm, and emotional distress
2	Access by unauthorized staff	Improper access control or misuse of credentials	Weak role-based access design or human error	Misuse of personal data and breach of confidentiality
3	Loss of patient data	System failure or accidental deletion	Lack of proper backup or recovery systems	Loss of medical history affecting treatment care
4	Sharing data with wrong recipient	Human error or system malfunction	Weak validation processes or operational errors	Unauthorized disclosure of sensitive information
5	System unavailability	Server failure	Infrastructure issues or lack of maintenance	Delay in healthcare services and access to data

4.1.b Method

Explain the details of the method followed to assess and manage risk and provide the necessary information to interpret the following:

- Likelihood and severity levels and their meanings (often a 2 to 5 levels scale is used).
- Risk metrics.
- How to prioritise risks.
- Risk acceptance levels.

If an established method is used, provide the link to the external source introducing this method⁷.

The risk assessment was conducted using a qualitative, risk-based approach aligned with GDPR principles and standard risk management practices. Risks were evaluated based on two key

⁷ For example, the documents listed in the Annex included in the explainer document.

parameters: likelihood of occurrence and severity of impact on the rights and freedoms of data subjects.

Likelihood represents the probability of a risk materialising and is assessed on a three-level scale: low, medium, and high. Severity represents the potential impact on individuals, ranging from minimal inconvenience to significant harm such as privacy violations, emotional distress, or misuse of sensitive personal data.

Risk levels are determined by combining likelihood and severity using a qualitative risk matrix, resulting in classifications of low, medium, or high risk. High risks are prioritised for immediate mitigation, medium risks are addressed through appropriate technical and organisational controls, and low risks are monitored as part of ongoing risk management.

Residual risk is assessed after the implementation of controls to determine whether the remaining risk is acceptable. Risks are considered acceptable only when reduced to a manageable level that does not adversely impact the rights and freedoms of data subjects.

This methodology is aligned with the GDPR risk-based approach and is informed by EDPB DPIA guidelines and ISO/IEC 27001 risk management principles.

Risk ID	Risk Description	Likelihood	Severity (Impact on Data Subjects)	Inherent Risk	Existing Controls	Residual Risk	Risk Owner
R-01	Unauthorized access to patient data	High (4)	Severe (5) – Exposure of sensitive health data leading to privacy violation, emotional distress, and loss of confidentiality	High	Multi-factor authentication (MFA), role-based access control, encryption, audit logging	Medium	IT Head
R-02	Delay in breach notification	Medium (3)	High (4) – Delay may prevent data subjects from taking timely protective measures, increasing risk of harm	High	Incident response SOP, security monitoring, escalation procedures	Medium	Compliance Officer
R-03	Incorrect sharing of medical reports	Medium (3)	High (4) – Disclosure to unintended recipients leading to privacy breach and loss of trust	High	Data validation checks, access restrictions, staff training	Medium	Operations Head
R-04	Data loss due to system failure	Low (2)	High (4) – Loss of medical records potentially affecting diagnosis and continuity of care	Medium	Cloud backups, disaster recovery mechanisms, redundancy systems	Low	IT Team

4.1.c Inherent risk assessment

Note: If available, this table can be supplemented with one or more diagrams, charts, maps, priority lists, etc. documenting inherent risk assessment from different perspectives.

	Risks to the data subject's rights and freedoms (include scenarios laid out in the first column in 3.1 and 4.1.a)	Likelihood⁸	Severity⁹	Modulating factors	Risk level	Discuss whether the risk is acceptable or not
1	Unauthorized access to patient data	High (4)	Severe (5)	Highly sensitive health data, large user base	High	Not acceptable
2	Delay in breach notification	Medium (3)	High (4)	Regulatory obligation	High	Not acceptable
3	Incorrect sharing of medical reports	Medium (3)	High (4)	Human involvement, operational errors	High	Not acceptable
4	Data loss due to system failure	Low (2)	High (4)	Critical nature of medical records, dependency on system availability	Medium	Not acceptable

4.2 Action plan

4.2.a Additional mitigating measures

Note: Include in this table all types of measures (see the different categories in section 2.3)

	Technical, legal/contractual and organisational measures	Mitigated risks (considering 4.1.c)	Discussion of appropriateness and effectiveness	Implementation status (partially implemented/implemented)
1	Multi-factor authentication (MFA) for system access	Unauthorized access to patient data	Adds an additional layer of authentication and reduce risk of unauthorized access	☐ Planned ☐ Partially implemented ☒ Implemented

⁸ A risk in data protection may be deemed non-acceptable if the potential severity of its impact is very high, even when its likelihood of occurring is low. This means that if the consequences for data subjects could be extremely serious, the risk may be considered unacceptable, regardless of how rarely the event is expected to occur.

⁹ Idem.

2	Regular employee privacy and security awareness training	Incorrect sharing of medical records	Reduces human error and improves handling of sensitive data	✓ Implemented
3	Automated incident detection and breach notification mechanism	Delay in breach notification	Enables timely detection and reporting of incidents	✓ Partially implemented
4	Periodic vulnerability assessments and security audits	Data breach and cybersecurity threats	Identifies and mitigate system vulnerabilities proactively	✓ Planned
5	Data processing agreements (DPAs) with third-party vendors	Third-party processing risks	Ensures processor comply with data protection obligations	✓ Implemented
6	Backup and disaster recovery procedures	Data loss due to system failure	Ensures availability and recovery of critical healthcare data	✓ Implemented

4.2.b Residual risk assessment

	Reassessed risks to the data subject's rights and freedoms	Additional mitigating measures that apply	Residual likelihood	Residual severity	Residual risk level	Discuss whether the risk is acceptable or not
1	Unauthorized access to patient data	MFA, encryption, role-based access, audit logs	Medium (3)	High (4)	Medium	Acceptable after implementation of safeguards
2	Delay in breach notification	Incident response SOP, automated alert mechanism	Low (2)	Medium (3)	Low	Acceptable
3	Incorrect sharing of medical reports	Validation checks, staff training, restricted access	Low (2)	Medium (3)	Low	Acceptable
4	Data loss due to system failure	Cloud backup, disaster recovery procedures	Low (2)	Medium (3)	Low	Acceptable

4.2.c Plan

Provide information about the necessary activities to properly add these new measures to the processing, so as to properly manage the risks for the rights and freedoms of individuals, and to monitor, review and update the proposed measures once the processing is being carried out.

Activity / Action	Responsible Team	Timeline	Monitoring/ Review Mechanism	Supporting Documents/ Annexes
Implement multi-factor authentication (MFA)	IT Security Team	Within 2 months	Quarterly access review and audit logs	Access Control Policy
Conduct employee privacy and security awareness training	HR & Compliance Team	Every 6 months	Training attendance and assessment review	Training SOP
Perform vulnerability assessments and security audits	IT Security Team	Quarterly	Audit reports and remediation tracking	Security Audit Reports
Implement automated breach detection and notification mechanism	IT & Compliance Team	Within 3 months	Incident monitoring and response review	Incident Response SOP
Review and update Data Processing Agreements (DPAs) with vendors	Legal & Compliance Team	Annually	Vendor compliance review	Vendor Management Policy
Test backup and disaster recovery procedures	IT Operations Team	Every 6 months	Recovery testing reports	Disaster Recovery SOP
○ Specific activities, responsible team, timelines, etc. ○ Links to external documentation or annexes with the details.				

5 INVOLVEMENT OF INTERESTED PARTIES

5.1 DPO advice

- If there is a DPO (or a similar function), provide their opinion, conclusions and recommendations concerning the envisaged processing.
- Explain how the DPO's advice has been implemented.

5.2 Views of data subjects or their representatives

- Where appropriate, provide the data subjects' (or their representatives') opinion, conclusions and recommendations concerning the envisaged processing.
- Explain their participation in the DPIA process, including explanations of why it has not been considered appropriate for them to participate or why it has not been possible for them to do so.

Direct consultation with data subjects was not conducted as this DPIA is based on a simulated healthcare processing scenario. However, common expectations relating to confidentiality, transparency, security, and protection of sensitive health data were considered during the assessment process.

Participation of data subjects was considered impractical for the purposes of this assessment. Nevertheless, the DPIA incorporates safeguards and measures intended to protect the rights and freedoms of individuals, taking into account the sensitivity of healthcare-related personal data and general expectations of privacy.

6 CONCLUSION AND DECISION

Based on the assessment of risks and rights, the following decision has been taken:

- ☐ **REJECTED:** The processing must be abandoned.
- ☐ **CONSULTATION:** The processing will be consulted with the SA (see **Error! Reference source not found.**).
 - ☐ Yes, the data controller cannot find sufficient measures to reduce the risks to an acceptable level (i.e. the residual risks are still high) and does not wish to abandon the processing.
 - ☐ Yes, there is a national law requiring the controller to consult with, and/or obtain prior authorisation from, the SA in relation to processing by a controller for the performance of a task carried out by the controller in the public interest, including processing in relation to social protection and public health (Article 36(5) GDPR).
- ☒ **APPROVED:** The processing may proceed [immediately]. The residual risks are acceptable and there is no national law requiring consultation or prior authorisation from the Supervisory Authority (Article 36(5) GDPR).
- ☐ **CONDITIONALLY APPROVED:** The processing may proceed only after the following conditions are met:
 - *Condition 1:* _____
 - *Condition 2:* _____

Optionally, justify the decision made:

